

NoteMD — defect closure pack

Prepared 1 October 2026, for the clinical hazard log, safety case and independent penetration-test handover.

Seven defects were identified during the pre-pilot security and safety review. All seven are fixed, deployed to production, and covered by automated tests that reproduce the original failure.

Summary

REF	DEFECT	SEVERITY	FIXED	DEPLOYED	COMMIT
F-002	Any account could read any clinician's patient records	Critical	17 Sep 2026	21 Sep 2026	dee9832
F-003	Any account could promote itself to administrator	High	17 Sep 2026	21 Sep 2026	dee9832
F-004	Audit entries could be attributed to another user	High	17 Sep 2026	21 Sep 2026	dee9832
F-007	A late transcription result could enter the next patient's letter	High (clinical safety)	17 Sep 2026	21 Sep 2026	63b7434
F-006	Two consultations in different tabs overwrote each other	Medium-high (clinical safety)	17 Sep 2026	21 Sep 2026	fa7d499
F-005	Rejected database writes wrote patient data into server logs	High	17 Sep 2026	21 Sep 2026	430c3c7
F-001	A draft letter could be emailed without clinician review	High (clinical safety)	17 Sep 2026	21 Sep 2026	08d3fd6

Supporting change: identifier minimisation, commit `be6c65c` , deployed 21 September 2026.

All production edge functions were redeployed on **21 September 2026 at 14:20 UTC** (`stripe-webhook` and `deepgram-token` at 14:29 UTC), and database migrations applied the same day.

F-002 — Cross-account access to patient records

Severity: critical. Found 17 September 2026 by automated hostile-access testing against a live database.

Defect. Secretary access is resolved at query time from `profiles.clinician_id` . The only policy governing profile writes restricted which *row* an account could update, not which *columns* . Any authenticated account could therefore set its own `clinician_id` to another clinician's user id and

immediately read that clinician's letters, recordings and stored audio.

Why it was not visible in review. Each policy is correct in isolation. The exposure exists only in the interaction between the profile update policy and the read policies on `letters`, `recordings` and storage. It was found by authenticating as one account and attempting to reach another's data, not by reading the schema.

Fix. Migration `20260917100000_lock_privileged_profile_columns.sql`. A trigger prevents `role`, `clinician_id` and `user_id` from being set by the account itself, on both INSERT and UPDATE. Column-level grants were rejected as an approach because they would require enumerating every safe column and would silently reject writes to any column added later.

Legitimate function preserved. Secretary assignment runs through the `manage-secretary` function using the service role and is unaffected.

Verification. `src/test/idor.integration.test.ts` — attempt recorded as "Self-assign as secretary of another clinician": *blocked, clinician_id rejected*. Positive controls confirm ordinary profile edits still succeed.

F-003 — Self-promotion to administrator

Severity: high. Same root cause and same fix as F-002: `profiles.role` was self-assignable.

Verification. Hostile-access attempt "Self-promote to admin": *blocked, role is now "clinician"*.

F-004 — Audit entries attributable to another user

Severity: high. Consequence of F-002. Having self-assigned as a clinician's secretary, an account could write audit entries attributed to that clinician.

Fix. Closed by the F-002 fix, plus the attribution rule in `log_audit_event`, which derives the actor from `auth.uid()` and records a mismatched subject as a denied attempt rather than accepting it.

Verification. Hostile-access attempt "Forge an audit entry against another user": *blocked, recorded against self, outcome "denied"*.

F-007 — Cross-patient transcription

Severity: high, clinical safety. Found 17 September 2026 during functional concurrency review.

Defect. Dictation is transcribed in ten-second segments, each dispatched asynchronously and appended to the live transcript when it returns. The drain before the review screen waits a maximum of eight seconds, then proceeds. A slower segment could therefore still be in flight after the clinician had finished, generated

the letter and begun recording the next patient. On return it appended to whichever transcript was then current — placing one patient's spoken words into another patient's transcript, and from there into their letter.

Fix. Commit `63b7434` . A session token is generated when a recording starts. Each segment captures the token before dispatch and discards its result if the session has changed. The same guard was applied to the streaming path, because providers commonly emit a final result as the socket closes and the socket is not torn down until cleanup runs.

Acceptance evidence for the hazard log. `src/test/session-isolation.test.ts` demonstrates the defect rather than asserting the fix:

TEST	PURPOSE	RESULT
"demonstrates the defect when unguarded"	Reproduces the original cross-contamination in an unguarded model	passes — contamination occurs
"discards the late result once guarded"	The same sequence with the guard applied	passes — transcript remains empty
"still applies results that belong to the current session"	Confirms the guard is not simply discarding everything	passes
"issues a different token for every session"	50 consecutive sessions, all distinct	passes
"captures the token before a segment is sent and checks it after"	Asserts the check precedes the append in shipped code	passes
"applies the same guard to streamed results"	Covers the WebSocket path	passes

The third test matters: a guard that discarded every result would satisfy the second test alone.

F-006 — Cross-tab session loss and wrong-patient recovery

Severity: medium–high, clinical safety. Found 17 September 2026.

Defect. The crash-recovery snapshot was stored at a single `localStorage` key per user. That storage is shared by every browser tab on the origin, so two consultations open simultaneously wrote to the same key roughly every three seconds. One session was lost outright, and the surviving snapshot could be offered for recovery in the other tab under a different patient's name.

Fix. Commit `fa7d499` . Snapshots are keyed per tab using an identifier held in `sessionStorage` , which is per-tab by definition and survives a reload. A snapshot left by a closed tab remains recoverable through a fallback to the freshest snapshot belonging to the same user, and stale snapshots are cleared at that point rather than persisting until sign-out.

Interface change relevant to the hazard log. The recovery prompt now states the patient name first, states explicitly when no patient name was recorded rather than rendering an empty gap, and says when a snapshot came from a different tab or window. That name is the only information a clinician can check a recovered transcript against before restoring it.

Acceptance evidence. `src/test/local-phi.test.ts` :

TEST	RESULT
"keeps two concurrent tabs from overwriting each other"	passes
"lists a user's slots newest first so the freshest is recoverable"	passes
"never lists another user's slots"	passes
"gives each tab a stable identifier that survives a reload"	passes
"names the recorder's slot after the tab"	passes
"purges every tab's slot on sign-out"	passes

The fifth test is the regression guard: the storage-layer tests alone would have passed against the defective code, because the storage layer always accepted an arbitrary key. What regressed the behaviour was the recorder using one fixed key for every tab, and that is what is asserted.

F-005 — Clinical content in server logs

Severity: high. Found 17 September 2026 during log review.

Defect. Every edge function ended with a catch-all that logged the error object. When the database rejects a write it returns the rejected row in the error's `details` field, so a failed letter insert wrote the patient's name, NHS number and transcript into retained server logs.

This was not hypothetical. The autosave fault reported earlier in the year was producing exactly this class of rejection, repeatedly, in production.

Fix. Commit `430c3c7` . `redactError()` reduces a caught value to `name` , `code` , `status` and a message capped at 160 characters. `details` and `hint` are dropped outright rather than truncated, and their size recorded so the omission is visible. `body` , `response` , `config` and `request` are never read. Applied at all 42 logging call sites across 11 functions and 3 shared modules.

Safe-log regression evidence. See `evidence/log-redaction-regression.md` , which demonstrates this against a genuine constraint violation produced by the live database — not a fixture. Summary:

CHECKED FOR IN CURRENT LOG OUTPUT	PRESENT
Patient name	no
NHS number	no
Clinical narrative	no
Row dump marker (<code>Failing row</code>)	no

Diagnostic value is retained: the error code and the violated constraint both appear.

Historical entries. Edge function logs are retained by Supabase on a rolling window set by the project plan. NoteMD does not export, copy or forward them, and no application code writes them to any other store. Entries written before the fix was deployed age out on the platform's normal schedule without further action. All such entries arose from synthetic and development traffic during the window the defect existed; the audit trail records no production letter-send failures of this class in that period.

F-001 — Unreviewed letters could be sent

Severity: high, clinical safety. Found 16 September 2026 during the Draft/Reviewed workflow verification.

Defect. Two routes crossed the stated safety boundary that AI generation must never constitute clinician approval:

1. `send-letter-email` accepted any letter regardless of status and then marked it exported. A letter that had never left `draft` could be emailed and recorded as sent, with no clinician action in between.
2. `generate-letter` invoked `send-letter-email` directly for clinicians with auto-send enabled, so an AI draft was emailed at the moment of generation and the clinician never saw it.

Fix. Commit `08d3fd6` .

Server-side restriction — acceptance evidence for the safety case. The restriction is enforced on the server, in the single function through which all sending passes, not in the user interface:

PROPERTY	EVIDENCE
Only <code>reviewed</code> or <code>exported</code> letters may be sent	<code>APPROVED_FOR_SEND</code> excludes <code>draft</code> ; asserted by <code>src/test/approval-gate.test.ts</code>
The check precedes any sending work	Test asserts the gate appears before the provider call in source order
Refusal is distinguishable from a delivery failure	HTTP 409 with <code>needs_review: true</code>
Refusal is recorded	Audit event <code>letter.email_failed</code> , outcome <code>denied</code> , reason <code>not_reviewed</code>
Generation cannot send	<code>generate-letter</code> contains no call to <code>send-letter-email</code> ; asserted with comments stripped so documentation cannot satisfy the test
Auto-send moved to the review action	Fires on the clinician's save, asserted in <code>src/test/approval-gate.test.ts</code>

Live verification against staging, 29 September 2026: a letter in `draft` was submitted for sending and refused with HTTP 409, recorded in the audit trail as `letter.email_failed / denied / not_reviewed` . The same letter in `reviewed` status was accepted.

Behaviour change. Clinicians with auto-send enabled must now open and save each letter, at which point it sends automatically. Previously the letter was sent at generation and they did not see it first.

Identifier minimisation

Commit `be6c65c` , deployed 21 September 2026.

The letter prompt previously carried the patient's name and NHS number. These are now replaced with placeholder tokens and reinstated on NoteMD's own server after generation, so the structured identifiers are not transmitted to the AI provider.

This is **data minimisation, not anonymisation**: the transcript is still transmitted and a name spoken aloud during a consultation is inherent to it.

Relevant to the hazard log: this is deliberately **not** a general de-identify/re-identify pipeline. There is no matching step. Substitution occurs on a single letter, within the function call that produced it, using the same two variables written to that letter's own record. A test asserts that a letter cannot acquire another patient's identifiers. Replacement is a literal string operation rather than a pattern match, so names containing regular-expression metacharacters — `O'Brien-Smith` , `Anne-Marie [Jr]` , `A+B Patel` — round-trip unchanged.

Before sending, the fully assembled prompt is checked for the identifiers held for that patient and the request is refused if either is present. This covers the case where a clinician's own letter template reintroduces an identifier.

Regression suite

Run 1 October 2026.

Test Files 20 passed | 1 skipped (21)
Tests 300 passed | 24 skipped (324)

The skipped file is the hostile-access suite, which is skipped unless database credentials are supplied; its results are below. Every defect above has at least one test that reproduces the original failure, so none can recur silently.

Relevant suites:

SUITE	TESTS	COVERS
idor.integration.test.ts	24	Cross-account access, privilege escalation, audit forgery, rate limiting, session revocation
audit-trail.test.ts	17	Append-only enforcement, attribution, clinical-content exclusion
session-isolation.test.ts	10	F-007, F-006, duplicate submission
approval-gate.test.ts	11	F-001
log-hygiene.test.ts	9	F-005
identifier-minimisation.test.ts	16	Identifier minimisation
local-phi.test.ts	18	Browser-held patient data, F-006
acs-email.test.ts	23	Email signing, idempotency
security-headers.test.ts	12	Content Security Policy, transport headers
environment.test.ts	11	Staging/production separation

Hostile-access test output

Run 1 October 2026 against the staging database with real accounts and real tokens. **24 tests, 18 recorded access attempts, all refused.**

SCENARIO	ACTOR	TARGET	BLOCKED
List all letters	Clinician A	B's letter	yes
Fetch letter by manipulated id	Clinician A	B's letter	yes
Fetch recording by manipulated id	Clinician A	B's recording	yes
Update another clinician's letter	Clinician A	B's letter	yes
Delete another clinician's recording	Clinician A	B's recording	yes
Download another clinician's audio	Clinician A	B's audio	yes
List another clinician's storage folder	Clinician A	B's folder	yes
Read another clinician's profile	Clinician A	B's profile	yes
Secretary modifies assigned clinician's letter	Secretary of A	A's letter	yes
Secretary reads unassigned clinician's letter	Secretary of A	B's letter	yes
Secretary downloads unassigned clinician's audio	Secretary of A	B's audio	yes
Self-assign as secretary of another clinician	Outsider	A's records	yes
Self-promote to admin	Outsider	own role	yes
Forge an audit entry against another user	Outsider	A's audit trail	yes
Modify an audit record	Outsider	audit log	yes
Consume a rate-limit allowance unauthenticated	Anonymous	counters	yes
Read and reset own rate-limit counters	Outsider	counters	yes
Refresh a session after revocation	Revoked user	own session	yes

Attempts: 18 · Blocked: 18 · Not blocked: 0

Four positive controls confirm the system remains usable: ordinary profile edits, writing and reading one's own records, self-attributed audit events, and a secretary's permitted read of their assigned clinician's letters.

The suite refuses to run against the production project, and writes `evidence/idor-results.md` on every run.

Dependency scan

Run 1 October 2026.

SCOPE	ADVISORIES
Production dependencies (code reaching the browser)	0
All dependencies including build and test tooling	4 (3 moderate, 1 high)

At the start of this work there were 25 advisories, 13 of them reachable from production dependencies. The remaining four are in `vitest`, `esbuild` and their dependencies — build and test tooling that is never served to a user and is not present in the deployed bundle.

`npm run audit:prod` is the regression check and fails on any production-dependency advisory at moderate severity or above.

Recovery position

Confirmed from the Supabase management interface, 1 October 2026:

PROPERTY	VALUE
Region	<code>eu-west-1</code>
Daily physical backups	8 retained
Write-ahead log archiving	enabled
Point-in-time recovery	not enabled
Effective recovery point objective	up to 24 hours

A point-in-time restore test has not been performed, because point-in-time recovery is not enabled on the project. It cannot be exercised until the add-on is purchased. Enabling it would reduce the recovery point objective to approximately two minutes.

What has been performed is a full restore rehearsal using a logical backup, on 17 September 2026: both clinical tables were deleted in their entirety on staging and recovered, with row counts, a content checksum over every restored letter, and the foreign-key relationships between letters and recordings all verified identical. See `evidence/recovery-test.md`. That exercises capture, loss and recovery; it does not substitute for point-in-time recovery, which addresses a different risk — the window between nightly backups.

Administrative access was reviewed on 30 September 2026 and the register is at `evidence/production-access.md`.